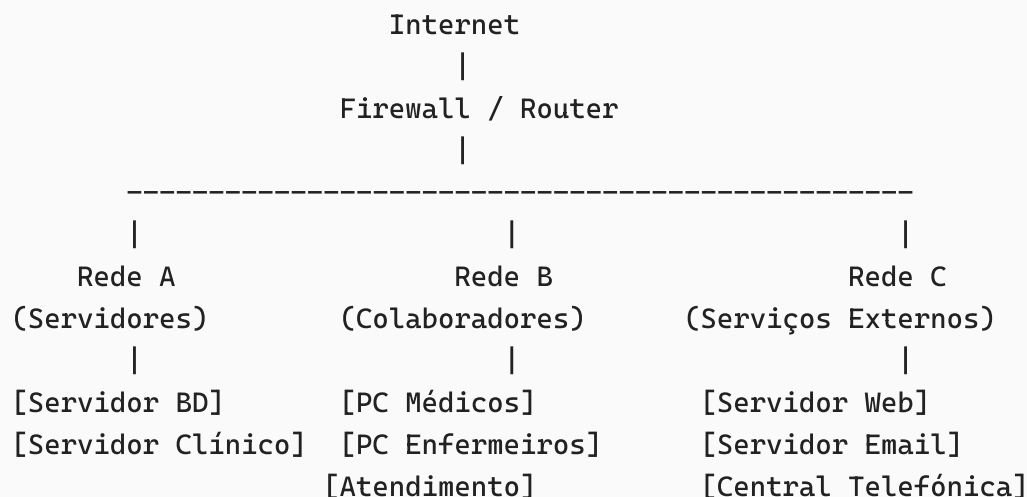


exame_2025

Exame – Análise de Risco e Sistemas de Informação

1) Análise de Risco – Clínica de Saúde

i) Esquema da Rede



O Servidor Web (Rede C) acede ao Servidor Clínico (Rede A) para permitir acesso remoto dos pacientes.

ii) Identificação de Ameaças

1. **Ataque externo (hacker)** – tentativa de acesso não autorizado à base de dados clínica.
2. **Erro humano** – colaborador elimina ou altera dados clínicos por engano.
3. **Malware/Ransomware** – infecção através de email ou acesso web.
4. **Falha elétrica ou de hardware** – indisponibilidade dos sistemas.
5. **Acesso indevido por colaborador interno** – abuso de privilégios.

iii) Identificação de Vulnerabilidades

1. Falta de segmentação rigorosa ou regras de firewall mal configuradas.
2. Passwords fracas ou reutilizadas.

3. Ausência de encriptação dos dados sensíveis.
4. Sistemas ou software desatualizados.
5. Falta de formação em segurança da informação dos colaboradores.

iv) Avaliação Qualitativa de Risco

Risco	Ameaça	Vulnerabilidade	Impacto	Probabilidade	Nível de Risco
R1	Ataque externo	Firewall fraca	Alto	Médio	Médio
R2	Erro humano	Falta de formação	Médio	Alto	Médio
R3	Ransomware	Email sem filtros	Alto	Médio	Médio
R4	Falha elétrica	Falta de redundância	Alto	Baixo	Baixo

A clínica aceita apenas risco baixo.

v) Plano de Tratamento de Risco

Risco R1 – Ataque Externo

- Medidas:
 - Firewall avançada
 - IDS/IPS
 - Encriptação da base de dados
- Estratégia: **Mitigar**

Risco R2 – Erro Humano

- Medidas:
 - Formação regular em segurança
 - Perfis de acesso por função
- Estratégia: **Reduzir**

Risco R3 – Ransomware

- Medidas:

- Filtros anti-spam
 - Backups regulares offline
 - Antivírus corporativo
 - Estratégia: **Mitigar**
-

2) Vantagens e Desvantagens da Cloud

Vantagens

- Redução de custos de infraestrutura
- Escalabilidade
- Acesso remoto
- Alta disponibilidade

Exemplo: utilização de AWS ou Azure para alojar backups.

Desvantagens

- Dependência da internet
- Questões de privacidade
- Custos variáveis
- Dependência do fornecedor

Exemplo: dados clínicos alojados fora da organização.

3) Plano de Continuidade de Negócio (PCN)

Um **Plano de Continuidade de Negócio (PCN)** é um conjunto de procedimentos e estratégias que permitem a uma organização **manter ou restabelecer rapidamente as suas atividades críticas** após a ocorrência de um incidente ou desastre.

A sua importância reside no facto de:

- **Reduzir o tempo de indisponibilidade** dos serviços essenciais;
- **Minimizar impactos financeiros, operacionais e reputacionais;**
- **Garantir a proteção da informação e dos ativos críticos;**
- **Assegurar o cumprimento de obrigações legais e contratuais;**

- **Aumentar a resiliência da organização** face a incidentes como falhas técnicas, ciberataques ou desastres naturais.

Assim, o plano de continuidade de negócio é fundamental para garantir que a organização consegue **responder a incidentes e continuar a operar**, assegurando a sua sobrevivência e confiança dos clientes e parceiros.

4) Backups vs RAID

Não. **O uso de backups não torna desnecessária a utilização de esquemas RAID**, pois ambos têm objetivos distintos e complementares.

Os **esquemas RAID** visam garantir a **disponibilidade do sistema** e a **tolerância a falhas de hardware**, permitindo que o serviço continue a funcionar mesmo em caso de avaria de um disco.

Os **backups**, por sua vez, servem para a **recuperação de dados**, protegendo contra apagamentos acidentais, ataques, corrupção de informação ou falhas graves.

Assim, enquanto o RAID reduz o tempo de indisponibilidade e evita perdas imediatas por falha de disco, os backups permitem restaurar dados perdidos ou alterados. **Por isso, os backups não substituem o RAID, sendo ambos necessários para uma proteção adequada da informação.**

5) Avaliação Quantitativa e Plano de Tratamento

Numa análise de risco, a **avaliação quantitativa** permite atribuir valores numéricos à probabilidade de ocorrência e ao impacto dos riscos, tornando-os **mensuráveis e comparáveis**.

Essa quantificação influencia diretamente o **plano de tratamento de risco**, pois possibilita:

- **Priorizar riscos** com maior impacto financeiro ou operacional;
- **Justificar decisões** sobre mitigação, transferência, aceitação ou eliminação do risco;
- **Avaliar custo-benefício** das medidas de segurança, escolhendo controlos adequados ao nível de risco;
- **Alocar recursos** de forma mais eficiente.

Assim, ao fornecer dados objetivos sobre a magnitude dos riscos, a avaliação quantitativa orienta diretamente as estratégias e ações definidas no plano de tratamento de risco.